

02-PRIVILEGE-ESCALATION

Privilege Escalation Detection (Sudo monitoring)

Detection Scenario

This lab documents the detection of privileged command execution and unauthorized vertical privilege escalation attempts on a Linux host using Splunk Enterprise. The scenario simulates an attacker who has already established initial access with a low-privilege account and attempts to execute administrative tasks via

Objective

Detect privileged command execution, extract administrative payloads, and identify highly suspicious or critical sudo activities (such as credential access or persistence) through SIEM log telemetry.

Environment

- **Victim Server:** Ubuntu Server
- **SIEM Platform:** Splunk Enterprise
- **Log Source:** Linux authentication logs (/var/log/auth.log)
- **Monitored Control:** Sudo Execution & Session Logging

Attack Simulation

The post-exploitation phase was simulated directly on the victim machine by executing a sequence of suspicious elevated commands:

1. **Sudo Failure:** Multiple intentional password failures while attempting to invoke root access (sudo su).
2. **Privilege Escalation:** Successful invocation of a root shell (sudo su).
3. **Malicious Actions:** Execution of critical administrative commands associated with theft and persistence, such as reading sensitive files (sudo cat /etc/shadow) and unauthorized account creation (sudo useradd intruso).

Data Source

Log File	/var/log/auth.log
Index	main
Sourcetype	Ubuntu-Victima

Detection Logic & SPL Queries

1. Base Sudo Activity Detection (Resultados de búsqueda generales)

Query base para filtrar de manera masiva todos los eventos de auditoría que involucran el subsistema de sudo en el host afectado:

```
index=main sourcetype="Ubuntu-Victima" sudo
```

2. Privilege Escalation Commands Extraction (Extracción avanzada de comandos)

Query avanzada que aísla la cadena de texto de los comandos crudos ejecutados mediante el uso de expresiones regulares (rex), permitiendo tabular de forma limpia qué hizo el usuario:

```
index=main sourcetype="Ubuntu-Victima" sudo
| rex "COMMAND=(?<command>.*)"
| table time host user command -raw
```

3. Critical Sudo Tool Detection (Identificación de comandos críticos)

Query de caza de amenazas (Threat Hunting) orientada a detectar específicamente herramientas e intenciones tácticas peligrosas (lectura de hashes de contraseñas o creación de persistencia en el sistema):

```
index=main sourcetype="Ubuntu-Victima" sudo
| rex "COMMAND=(?<command>.*)"
| search command="*shadow*" OR command="*useradd*" OR command="*passwd"
```

4. Attack Path Correlation (Línea de tiempo correlacionada)

Uso del comando transaction para agrupar en un único bloque de tiempo (ventana de 5 minutos) la historia completa del ataque: desde el inicio de sesión exitoso por SSH hasta el escalamiento y los comandos ejecutados:

```
index=main sourcetype="Ubuntu-Victima" ("Accepted password" OR "sudo")
| rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| transaction user maxspan=5m
```

Analysis

The security analysis successfully correlated and monitored the chronological operational flow of an internal privilege escalation attempt. Splunk telemetry recorded initial authentication failures for elevated privileges followed by session openings under the root context.

The identification of arguments like /etc/shadow and useradd provides deterministic evidence of post-compromise behaviors (Credential Access and Persistence tactics) rather than standard operational maintenance.

Findings

- **Authentication Failures in Sudo:** Multiple sudo: authentication failure log records identified prior to elevation.
- **Session Hijacking / Transition:** Telemetry confirmed a transition from standard user session to administrative root privileges (sudo: session opened).
- **Critical Commands Logged:** Direct visibility of administrative payload execution via the command extraction filter.
- **High-Risk Indicators Detected:** Flagged actions directly related to backdooring systems (creation of user intruso).

MITRE ATT&CK Mapping

- **Tactics:** Privilege Escalation & Credential Access
- **Technique:** T1548.003 - Abuse Elevation Control Mechanism: Sudo

Impact

An unauthorized privilege escalation allows local or remote attackers to bypass role-based security policies, access password hashes for offline cracking, compromise host confidentiality completely, and establish permanent persistence mechanisms.

Classification

True Positive (Validated laboratory simulation of privilege escalation).

Recommendations

1. Restrict the list of binaries a user can run via the /etc/sudoers configuration file, strictly applying the principle of least privilege.
2. Establish real-time alerting profiles within Splunk Enterprise for specific strings like useradd, chown, or cat *shadow inside sudo telemetry.
3. Audit and restrict standard user access to high-risk binary execution paths.
4. Integrate advanced continuous kernel monitoring controls (such as auditd) to gain system-call level execution insights alongside traditional authentication logs.

Screenshots Required

1. **Sudo execution events:** Eventos base en Splunk donde se leen las líneas de sudo: authentication failure y session opened.

The screenshot shows a Splunk search interface with the following details:

- Search Bar:** `index=main sourcetype="Ubuntu-Victima" sudo` with a 30 minute window.
- Results:** 27 of 42 events matched. The search is in Smart Mode.
- Navigation:** Buttons for Job, Stop, Refresh, and Download are visible.
- Table View:** The 'Statistics (27)' tab is selected. The table shows 20 events per page. The first event is: `2026-03-25T00:01:54.483052+00:00 ubuntuuser sudo: pam_unix(sudo:session): session opened for user root(uid=0) by mathias(uid=0)`.

2. **User privilege activity / Extraction:** Vista tabular en Splunk mostrando la columna personalizada de command gracias al uso del comando rex.

The screenshot shows a Splunk search interface with the following details:

- Search Bar:** `index=main sourcetype="Ubuntu-Victima" sudo` with a 1 hour window. A `rex "COMMAND=(?<command>.*)"` command is used to extract the command field.
- Results:** 48 of 49 events matched. The search is in Smart Mode.
- Navigation:** Buttons for Job, Stop, Refresh, and Download are visible.
- Table View:** The 'Events (48)' tab is selected. The table shows 20 events per page. The first event is: `2026-03-25T00:01:54.483052+00:00 ubuntuuser sudo: pam_unix(sudo:session): session opened for user root(uid=0) by mathias(uid=0)`.
- Fields List:** A sidebar on the left shows 'SELECTED FIELDS' (host, source, sourcetype) and 'INTERESTING FIELDS' (COMMAND, command, date_hour, date_mday, date_minute, date_month, date_second, date_wday, date_year, date_zone, index, linecount, punct, PWD, splunk_server, timeendpos, timestartpos).

3. SPL search results (Critical Commands): Captura filtrada mostrando únicamente las alertas críticas generadas por los comandos sospechosos (useradd/shadow)

The screenshot shows a Splunk search interface with the following details:

- Search Query:**

```
index=main sourcetype="Ubuntu-Victima" sudo
| rex "COMMAND=(?<command>.*)"
| search command="*shadow*" OR command="*useradd*" OR command="*passwd*"
```
- Results:** 3 of 42 events matched. No Event Sampling.
- Visualization:** Timeline format. Zoom Out. + Zoom to Selection. X Deselect. 1 minute per column.
- Fields:** Format. Show: 20 Per Page. View: Raw.
- Event List:**

Time	Source	Event
2026-03-25T00:01:14.190477+00:00	ubuntuserver	sudo: root : TTY=pts/2 ; PWD=/home/mathias ; USER=root ; COMMAND=/usr/bin/passwd intruso
2026-03-25T00:01:05.665073+00:00	ubuntuserver	sudo: root : TTY=pts/2 ; PWD=/home/mathias ; USER=root ; COMMAND=/usr/sbin/useradd intruso
2026-03-25T00:00:40.514003+00:00	ubuntuserver	sudo: root : TTY=pts/2 ; PWD=/home/mathias ; USER=root ; COMMAND=/usr/bin/cat /etc/shadow

4. Transaction Timeline: Visualización de la correlación agregada usando la consulta transaction, exponiendo el flujo de ataque unificado.

The screenshot shows a Splunk search interface with the following details:

- Search Query:**

```
index=main sourcetype="Ubuntu-Victima"
("Accepted password" OR "sudo")
| rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| transaction user maxspan=5m
```
- Results:** 1 of 43 events matched. No Event Sampling.
- Visualization:** Timeline format. Zoom Out. + Zoom to Selection. X Deselect. 1 minute per column.
- Fields:** Format. Show: 20 Per Page. View: Raw.
- Event List:**

Time	Source	Event
2026-03-25T00:00:02.932867+00:00	ubuntuserver	sudo: pam_unix(sudo:auth): authentication failure; logname=mathias uid=1000 euid=0 tty=/dev/pts/1 ruser=mathias rhost= user=mathias
2026-03-25T00:00:19.310149+00:00	ubuntuserver	sudo: pam_unix(sudo:auth): authentication failure; logname=mathias uid=1000 euid=0 tty=/dev/pts/1 ruser=mathias rhost= user=mathias